AN ILLUSTRATIVE ACADEMY CYBERSECURITY POLICY

Submitted by:

Adam Bello Ahmad

February 5th, 2026

Contents

PART 1: EXECUTIVE SUMMARY 1
PART 2: CYBERSECURITY POLICY 3
1. Introduction and Background 3
2. Password Management and Authentication 3
2.1 Password Construction and Length Requirements 3
2.2 Password Update Requirements 3
2.3 Password Reuse, Blocklisting and Prohibited Practices. 3
2.4 Default Credentials 4
2.5 Password Managers 4
2.6 Multi-Factor Authentication (MFA) 4
3. Cybersecurity Awareness and Training 4
3.1 Training Program Structure and Applicability 4
3.2 Core Cybersecurity Awareness Training (All Users) 5
4. Data Protection 5
4.1 Data Storage and Protection 5
4.2 File Sharing and Removable Media 6
4.3 Backups and Data Retention 6
5. Incident Response 6
5.1 Reporting Channels 6
5.2 Audit and Record-Keeping 7
5.3 Quick Steps for Staff and Students 7
6. Network Security 7
6.1 Firewall 7
6.2 Network Segmentation and Wi-Fi 7
6.3 Device Access Control 7
7. Remote Access 7
7.1 Approved Remote Access Methods 7
8. Policy Enforcement 8
8.1 Compliance and Consequences 8
8.2 Policy Acknowledgement 8
PART 3: POLICY ALIGNMENT WITH NIST CYBERSECURITY FRAMEWORK 2.0 9
APPENDIX A: MAPPING OF PASSWORD MANAGEMENT REQUIREMENTS TO NIST SP 800-63B-4 11
REFERENCES 12

PART 1: EXECUTIVE SUMMARY

This Cybersecurity Policy establishes the governance framework for how The Academy protects its digital systems, information assets, and daily operations. As a nursery, primary, and secondary educational institution, the academy relies heavily on digital technologies to support teaching, learning, administration, assessments, communication, and data storage. These systems handle sensitive information, including academic documents, student records, staff data, and other personal information, much of which relates to minors. Without clear and enforceable cybersecurity controls, this reliance creates significant exposure to operational disruption, data loss, reputational damage, and legal or regulatory consequences.

Education is among the most targeted sectors for cyberattacks, with threat actors exploiting vulnerabilities in authentication, inconsistent controls, and limited user awareness (Microsoft, 2024). A single successful incident can disrupt academic activities, compromise confidential information, and undermine trust among parents, staff, regulators, and other stakeholders. This policy exists to reduce those risks by defining clear expectations for user behaviour, system protection, accountability, and incident handling across the academy.

The primary objectives of this policy are to safeguard the confidentiality, integrity, and availability of the academy's information systems and data; reduce the likelihood and impact of cyber incidents; promote responsible use of technology; and ensure compliance with applicable legal and regulatory requirements. The policy adopts a preventive, detective, and responsive approach to cybersecurity, combining technical controls, administrative measures, and user awareness to address both human and system-related risks.

This policy is informed by recognized cybersecurity best practices, including principles from the **NIST Cybersecurity Framework (CSF) 2.0** and **NIST Special Publication 800-63B-4 Digital Identity Guidelines**, and supports compliance with the **Nigeria Data Protection Act, 2023**. Alignment with these standards ensures that the controls implemented by the academy are reasonable, evidence-based, and defensible, while remaining practical for an educational environment.

Key policy areas include password management and authentication, cybersecurity awareness and training, data protection, network security, backup and recovery, secure remote access, and incident response. Strong authentication requirements, including secure password practices and multi-factor authentication, address one of the most common causes of cyber incidents: compromised credentials. Ongoing staff training, role-based awareness for high-risk roles, and age-appropriate student education reduce human error and strengthen the academy's first line of defense. Data protection measures, backups, and defined retention practices limit the impact of data loss and system failures, while structured incident response procedures ensure timely and coordinated handling of security events.

This policy applies to all staff, students, contractors, third-party service providers, and any individual or system that accesses or manages The Academy's information systems or data. Compliance is mandatory. Executive leadership is responsible for supporting enforcement, allocating resources, and reinforcing that cybersecurity is a shared responsibility. Through this policy, The Academy demonstrates due diligence, reduces risk, and strengthens its resilience against evolving cyber threats.

PART 2: CYBERSECURITY POLICY

1. Introduction and Background

The Academy is an ideal a private nursery, primary, and secondary school in Nigeria, it uses digital systems to support teaching, learning, administration, and the management of sensitive school information. This Cybersecurity Policy defines how the academy protects these systems and the data they contain from loss, misuse, disruption, and unauthorized access. The purpose of this policy is to establish and enforce clear cybersecurity controls that safeguard sensitive information and reduce the likelihood and impact of cyber incidents. It applies to all staff, students, and approved third-party service providers who access or manage school data through academy systems or approved platforms, ensuring the confidentiality, integrity, and availability of its systems.

2. Password Management and Authentication

This section defines how passwords and authentication are managed within The Academy systems and aligns with **NIST Special Publication 800-63B-4 Digital Identity Guidelines.**

Detailed mapping of these requirements to NIST SP 800-63B-4 controls is provided in **Appendix A.**

2.1 Password Construction and Length Requirements

All passwords within The Academy systems shall have a minimum length of eight (8) characters for non-privileged accounts and at least twelve (12) characters for privileged accounts.

The use of passphrases is encouraged as this practice improves memorability and systems shall allow all printable characters and support passwords up to sixty-four (64) characters.

The school shall not enforce rules requiring specific combinations of characters as strict complexity rules often lead to predictable password patterns and unsafe user behavior. Instead, users are encouraged to create passwords using a combination of uppercase letters, lowercase letters, numbers and special characters where appropriate to improve password strength.

2.2 Password Update Requirements

Passwords shall not be changed on a periodic basis. Password changes shall only be required when there is evidence or suspicion of compromise, when a user forgets their password, or when an account recovery event occurs.

This decreases the likelihood of insecure password practices as a result of frequent forced password changes.

2.3 Password Reuse, Blocklisting and Prohibited Practices.

All systems shall check new passwords against a blocklist of commonly used, previously used, or known-compromised passwords. Passwords on this list shall be rejected.

The academy shall not allow the use of password hints that are visible before login. The school shall also not use security questions or knowledge-based authentication methods, as these can often be guessed or discovered through social engineering or public information.

Authentication systems shall enforce rate limiting on failed authentication attempts and provide feedback when authentication fails, in accordance with NIST SP 800-63B-4.

2.4 Default Credentials

All default passwords or credentials on devices, software and applications shall be changed before the systems are placed into operational use. Default credentials are often publicly documented and must not be relied upon for operational security.

2.5 Password Managers

School-approved password managers may be used for storing and generating passwords. Password managers must be protected with a strong master passphrase and multi-factor authentication where supported.

2.6 Multi-Factor Authentication (MFA)

Multi-factor authentication is mandatory for all accounts, including privileged, non-privileged and student accounts for system access. It provides an additional layer of protection to user accounts even if a password is compromised.

The primary MFA methods for the school shall be biometric authentication or approved authenticator applications. Other methods, such as SMS or email one-time passwords, may be used only where approved methods are unavailable and are not recommended due to lower security.

3. Cybersecurity Awareness and Training

This section defines the cybersecurity awareness and training program established to ensure that all staff and students understand cybersecurity risks, safe use of school systems, and how to recognize and report suspicious or malicious activity.

3.1 Training Program Structure and Applicability

The school shall maintain a formal cybersecurity awareness and training program applicable to all users of school systems, including staff and students.

a. **Staff Training**
   All staff shall complete cybersecurity awareness training upon onboarding and quarterly thereafter. Short monthly awareness sessions shall be conducted to address emerging or high-impact cyber threats.

b. **Student Cybersecurity Awareness**
   Students shall receive age-appropriate cybersecurity awareness education focused on safe use of digital systems, online safety and security concerns. Training shall be delivered through organized class activities and school programs. Students access school systems and they represent both potential targets and potential entry points for cyber threats.

c. **Role-Based Training**

Additional focused cybersecurity training shall be provided on a recurring basis to individuals whose roles increase organizational risk due to their authority, system access, or operational responsibilities. This includes, but is not limited to the proprietress, directors, principal, vice principals, heads of departments, IT and administrative staff.

3.2 Core Cybersecurity Awareness Training (All Users)

System users shall receive training on the following essential topics:

a. **Recognizing Cyber Threats:** Phishing, smishing, vishing, QR-code phishing, impersonation, suspicious links, fraudulent messages, deepfake scams, baiting and tailgating.
b. **Social Engineering and Manipulation:** How attackers use urgency, authority, scarcity, consensus/social proof and familiarity to trick users.
c. **Password Security:** Creating strong passwords or passphrases, using password managers safely, and protecting account credentials.
d. **Multi-Factor Authentication (MFA):** Using MFA to strengthen account security.
e. **Device Security:** Keeping devices updated, downloading from trusted sites, using antivirus/malware protection, and maintaining physical security.
f. **Safe Use of Email and Social Media:** Identifying suspicious messages, links, attachments and preventing public disclosure of the academy's confidential information.
g. **Secure File Sharing and Data Handling:** Protecting student, staff, and school information.
h. **Incident Reporting:** All staff and students shall be trained to promptly report suspected cyber incidents using the school's defined reporting channels. Staff must report incidents directly to IT Personnel, while students must report to their academic supervisor, who will escalate the report to IT.

4. Data Protection

This section defines how the school stores, protects, shares, backs up, and retains sensitive information, including student records, academic data, examination materials, staff information, and financial records.

4.1 Data Storage and Protection

All sensitive school data shall be stored and processed only on school-approved cloud platforms that provide role-based access control, activity monitoring, and compliance with recognized security standards and the Nigeria Data Protection Act, 2023. Sensitive data shall be protected using encryption both at rest and in transit.

Sensitive data shall not be stored on personal email accounts, personal cloud storage services, or unapproved systems, as these environments cannot be centrally secured, monitored, or backed up.

High-risk academic materials may be temporarily created on school-owned devices where necessary. Such devices must use full-disk encryption and endpoint protection, and final versions shall be stored on approved cloud systems.

Physical documents containing sensitive information shall be stored securely and destroyed when no longer required.

4.2 File Sharing and Removable Media

Sensitive data shall be shared only through approved cloud platforms or secure internal file-sharing systems. The use of removable media is restricted and permitted only when explicitly authorized. Technical controls shall be implemented to prevent unauthorized devices from copying or accessing sensitive data.

4.3 Backups and Data Retention

Critical systems and sensitive data shall be backed up automatically on a defined schedule and stored in a secure, logically separate environment. Core academic, administrative, and financial systems shall be backed up daily, while other systems shall be backed up weekly. Backup processes shall be monitored to ensure data integrity and successful completion.

Personal data and operational records shall be retained in accordance with the Nigeria Data Protection Act, 2023, which requires that personal data be retained only for as long as necessary to fulfill the purposes for which it was collected and processed.

Historical records required for legal, academic, evidentiary, or financial purposes shall be archived in a secure, tamper-resistant, long-term storage system. Archiving is distinct from backups and serves as the authoritative record of historical data.

Data that is no longer required shall be securely deleted or destroyed using methods that prevent unauthorized recovery.

5. Incident Response

IT Personnel shall provide first-level response to cybersecurity incidents, including confirming incidents, isolating affected systems, and attempting immediate recovery. Incidents beyond their capability shall be escalated to the **IT Manager**, who serves as the **Incident Response Lead** and is responsible for overall incident handling.

5.1 Reporting Channels

a. **Staff**
   Staff who suspect a cybersecurity incident shall immediately report it to IT Personnel in person or by phone.
b. **Students**
   Students shall report suspicious activity to their academic supervisor, who shall escalate the report to IT Personnel.

c. **School Management**
   The IT Manager shall notify school management of incidents that may impact operations, safety, reputation, or sensitive data.

5.2 Audit and Record-Keeping

IT Personnel shall document all reported cybersecurity incidents, including what happened, systems or users affected, and actions taken. Escalated incidents will be reviewed by the IT Manager to identify lessons learned and recommend simple improvements, helping the organization prevent similar issues in the future.

5.3 Quick Steps for Staff and Students

When a cybersecurity incident is suspected, staff and students must:

i. **Disconnect affected devices from the network immediately** to prevent potential spread. ii. **Do not shut down the device**, as shutting down may delete temporary logs and running information needed for investigation.
iii. **Do not attempt to investigate or fix the issue yourself.**
iv. **Do not delete files, emails, or messages** related to the incident.
v. **Report the incident immediately** using the approved channels (IT Personnel or academic supervisor).

6. Network Security

The school shall implement layered network security controls to protect systems, devices, and sensitive information from unauthorized access and cyber threats.

6.1 Firewall

A network firewall shall be deployed at the network edge, and device-level firewalls shall be enabled on school systems.

6.2 Network Segmentation and Wi-Fi

The school shall maintain separate business and guest networks. The business network shall be segmented by departments, including IT, academic, administrative, and financial systems. The guest network shall be isolated from the business network and restricted to internet access only. All school Wi-Fi networks shall use strong encryption and authentication to prevent unauthorized access.

6.3 Device Access Control

Access to the business network shall require authentication to ensure that only authorized users and approved devices configured to school security standards are permitted to connect.

7. Remote Access

Remote access to school systems is permitted only through secure, school-approved methods.

7.1 Approved Remote Access Methods

All remote access shall be conducted using the school-approved VPN and shall require multifactor authentication. Technical controls shall ensure that only authorized staff using approved devices that meet the school's security requirements can access school systems remotely

Staff shall not use public or untrusted Wi-Fi networks for accessing school systems unless unavoidable. Where unavoidable, connection through the school-approved VPN is mandatory.

8. Policy Enforcement

8.1 Compliance and Consequences

Compliance with the **The Academy Cybersecurity Policy** is mandatory for all individuals within its scope. Violations, whether through deliberate action, negligence, or repeated failure to follow required security practices, may result in disciplinary action in accordance with school regulations and applicable laws, including retraining, restriction or removal of system access, formal warnings, suspension of duties, termination of employment, or legal action where necessary.

8.2 Policy Acknowledgement

All staff shall be required to formally acknowledge that they have read, understood, and agreed to comply with the **The Academy Cybersecurity Policy**. Students shall be informed of applicable requirements through school guidelines and acceptable use agreements.

Policy Acknowledgement Statement:

I acknowledge that I have received, read, and understood the **The Academy Cybersecurity Policy**. I agree to comply with its requirements and understand that failure to do so may result in disciplinary or corrective action.

Name: _____
Role/Department: _____
Signature: _____
Date: _____

PART 3: POLICY ALIGNMENT WITH NIST CYBERSECURITY FRAMEWORK 2.0

The Academy Cybersecurity Policy aligns with all NIST Cybersecurity Framework core functions by providing balanced coverage across **Govern**, **Identify**, **Protect**, **Detect**, **Respond**, and **Recover**. The policy establishes clear leadership responsibility, accountability, and enforcement to support **Govern** and ensure cybersecurity activities align with the academy's educational, legal, and operational objectives. It **Identifies** and **Protects** critical systems and sensitive information through defined access controls, strong authentication, data protection, and user awareness. Continuous monitoring and logging enable the timely **Detection** of suspicious activity, while clearly defined incident reporting and response procedures ensure coordinated and effective **Response** when incidents occur. Finally, regular backups, data retention controls, and post incident reviews support system **Recovery** and continuous improvement, ensuring the academy can maintain operations and protect its community even in the event of a cyber incident.

NIST CSF Function	Policy Sections that Address It
Govern	1. Introduction and Background (establishes cybersecurity purpose, scope, and applicability); 3. Cybersecurity Awareness and Training (defines governance through user responsibility and ongoing education); 4.3 Backups and Data Retention (Ensures data retention meets legal/NDPA requirements); 5. Incident Response (defines leadership, roles, and accountability); 8. Policy Enforcement (establishes compliance expectations, consequences, and acknowledgement)
Identify	1. Introduction and Background (identifies systems, users, and assets in scope); 3. Cybersecurity Awareness and Training (builds organizational understanding of cyber risks and threat environment); 4. Data Protection (identifies sensitive data types and legal obligations, including NDPA); 5. Incident Response (establishes incident classification and reporting structures)
Protect	2. Password Management and Authentication (access control, credential security, MFA); 3. Cybersecurity Awareness and Training (human-layer protection against social engineering and misuse); 4. Data Protection (encryption, storage controls, removable media, backups); 6. Network Security (firewalls, segmentation, device access control); 7. Remote Access (VPN enforcement, approved devices)

Detect	3.2 Core Cybersecurity Awareness Training (threat recognition, phishing awareness, reporting); 5. Incident Response: Reporting Channels (detection through human reporting); 6.1 Firewalls and Monitoring (technical detection mechanisms).
Respond	5. Incident Response (incident leadership, escalation paths, and response authority); 5.1 Reporting Channels (structured reporting process); 5.2 Audit and Record-Keeping (response documentation and accountability); 5. 3 Quick Steps for Staff and Students (immediate containment actions)
Recover	4.3 Backups and Data Retention (system and data recovery capability); 5.3 Audit and Record-Keeping (post-incident learning and improvement).

APPENDIX A: MAPPING OF PASSWORD MANAGEMENT REQUIREMENTS TO NIST SP 800-63B-4

S/N	NIST SP 800-63B Requirement	How The Academy Policy Implements It
1.	Verifiers SHALL require memorized secrets to be at least 8 characters in length.	Policy requires a minimum of 8 characters for all non-privileged accounts and 12+ characters for privileged accounts as an additional protective measure
2.	Allow memorized secrets of at least 64 characters and all printable characters including spaces and Unicode	Policy permits passwords up to 64 characters and allows all printable characters and Unicode.
3.	Do not impose composition rules (no forced symbols/uppercase rules)	Policy explicitly states that character-type requirements are not enforced.
4.	Reject passwords found on blocklists of common or compromised passwords	Policy mandates blocklist checking for all new passwords.
5.	Do not require periodic password changes without evidence of compromise	Policy requires password changes only upon suspected or confirmed compromise.
6.	Prohibit password hints and knowledge based authentication	Policy bans password hints and security questions.
7.	Support usability: copy/paste, clear feedback, visible entry, 64-character support	Policy requires systems to support these usability features.
8.	Implement rate limiting and provide feedback on remaining attempts (minimum 10 attempts)	The policy requires systems to limit failed login attempts and to inform users when authentication fails.
9.	Encourage long passphrases for memorability	Policy encourages passphrases over short complex passwords.
10.	Require MFA and prefer phishing-resistant methods over SMS	Policy mandates MFA with biometrics/authenticator apps as primary methods.
11.	Provide alternate authentication options if a factor is lost or unavailable	Policy requires backup authentication methods for continuity.
12.	Change default credentials before operational use	Policy mandates removal of default credentials before deployment.

REFERENCES

1. National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce. https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf

2. National Institute of Standards and Technology. (2025). *Digital identity guidelines: Authentication and authenticator management (SP 800-63B, Version 4)*. U.S. Department of Commerce. https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63B-4.pdf

3. Nigeria Data Protection Commission. (2023). *Nigeria Data Protection Act, 2023*. https://cert.gov.ng/ngcert/resources/Nigeria_Data_Protection_Act_2023.pdf

4. Digital Care Hub. (n.d.). *Respond to a cyber incident: first steps*. https://www.digitalcarehub.co.uk/data-protection-and-cyber-security/cybersecurity/respond-to-a-cyber-incident/

5. Microsoft. (2024). *Microsoft Digital Defense Report 2024*. https://www.microsoft.com/security/security-insider/intelligence-reports/microsoftdigital-defense-report-2024